

SECCIÓN 1.1



¿Qué es un SOC y por qué es clave en Ciberseguridad?

Temas de esta sección:

- Definición de Security Operations Center (SOC)
- Objetivos principales: monitoreo, detección, respuesta
- Tipos de SOC: internos, externos (MSSP), híbridos
- Diferencia entre SOC y otros equipos (NOC, CERT, CSIRT)
- Cómo encaja el SOC en una estrategia de seguridad corporativa

1.1 | Definición de Security Operations Center (SOC)



Un **Security Operations Center (SOC)** es un equipo especializado dentro de una organización que se encarga de **monitorear, detectar, analizar y responder** ante posibles incidentes de seguridad que puedan afectar la información, los sistemas o las redes de una empresa.

Centro de comando

El SOC actúa como el centro de comando de la ciberseguridad. Su función es vigilar constantemente el entorno digital de la organización para identificar amenazas lo antes posible y minimizar su impacto.

Operación 24/7

Trabaja las 24 horas del día, los 7 días de la semana. La continuidad operativa es esencial para garantizar cobertura ante cualquier amenaza.

Herramientas especializadas

Utiliza sistemas como SIEM (Security Information and Event Management), que permiten ver y correlacionar miles de eventos y alertas de distintos sistemas tecnológicos en un mismo lugar.

1.1 | Objetivos principales: Monitorear · Detectar · Responder



El SOC tiene tres objetivos operativos centrales que guían su trabajo diario. Están conectados y forman la base de cualquier operación efectiva de seguridad.

MONITOREAR	DETECTAR	RESPONDER
El SOC realiza monitoreo continuo (24/7) de sistemas, redes, dispositivos y aplicaciones. Utiliza herramientas como SIEM, EDR o NDR para observar en tiempo real eventos y actividades sospechosas.	Una vez recopilada la información, el SOC analiza los datos para identificar comportamientos anómalos o amenazas reales. Usa correlación de eventos, análisis de comportamiento (UEBA) e inteligencia de amenazas.	Cuando una amenaza es confirmada, el SOC activa un proceso de respuesta a incidentes que puede incluir contención, erradicación, recuperación y comunicación interna.

1.1 | Ejemplo integrado: Monitoreo → Detección → Respuesta



1

MONITOREAR

Se detectan múltiples intentos fallidos de inicio de sesión desde una IP extranjera en el servidor de archivos de la empresa.

2

DETECTAR

El sistema SIEM detecta que, luego del acceso exitoso desde esa IP, se descargaron archivos sensibles a un servidor desconocido. Se genera una alerta crítica.

3

RESPONDER

El analista bloquea la IP maliciosa, desactiva la cuenta comprometida y documenta el incidente para escalarlo al equipo de respuesta (IR/CSIRT).

1.1 | Tipos de SOC: Internos, Externos (MSSP) e Híbridos



No todas las organizaciones tienen el mismo tamaño, presupuesto o equipo técnico. Por eso, existen tres modelos principales de SOC:

SOC INTERNO (In-house SOC)	SOC EXTERNO (MSSP)	SOC HÍBRIDO
Totalmente gestionado por la propia organización. Equipo propio de analistas, infraestructura y herramientas. ✓ Control total ✓ Alineación con políticas internas ✓ Personalización de reglas ✗ Altos costos operativos ✗ Requiere retención de talento Ideal para: grandes empresas, gobiernos, sectores críticos	La organización subcontrata el SOC a un proveedor especializado como Accenture, IBM Security o SecureWorks. ✓ Reducción de costos ✓ Acceso inmediato a expertos ✓ Escalabilidad y rapidez ✗ Menor control sobre decisiones ✗ Riesgos de privacidad y dependencia Ideal para: PyMEs, startups, empresas sin equipo interno	Combina recursos internos y externos. Por ejemplo, el monitoreo 24/7 lo hace un MSSP pero la respuesta forense la realiza un equipo interno. ✓ Equilibrio entre control y eficiencia ✓ Uso flexible de recursos ✓ Reduce carga operativa ✗ Mayor complejidad de coordinación ✗ Riesgo de solapamientos Ideal para: empresas medianas o grandes que quieren escalar sin perder control

1.1 | Diferencia entre SOC y otros equipos: NOC, CSIRT, CERT



Existen otros equipos clave que cumplen funciones complementarias al SOC. Comprender sus diferencias es fundamental para ubicar al SOC dentro del ecosistema de gestión de incidentes.

Equipo	Foco Principal	Función	Relación con SOC	Ejemplo
SOC	Seguridad digital activa (24/7)	Monitorea, detecta y responde ante amenazas de ciberseguridad.	Coordina con todos los demás equipos.	Detecta un escaneo de red sospechoso y alerta al equipo de IR.
NOC	Operaciones de red y disponibilidad TI	Se encarga de que los sistemas y servicios funcionen correctamente: servidores, conectividad, correo.	Si una falla tiene origen en un ataque, el SOC investiga y el NOC ejecuta.	Un DDoS cae sobre la red. El NOC actúa técnicamente; el SOC investiga el origen.
CSIRT	Respuesta específica a incidentes	Equipo especializado en investigar, contener y recuperar tras un incidente confirmado. Puede ser parte del SOC o separado.	Toma el control cuando el SOC escala un incidente crítico.	Se detecta ransomware. El SOC lo identifica; el CSIRT coordina la respuesta completa.
CERT	Coordinación nacional/sectorial	Similar al CSIRT, pero con alcance más amplio: nacional o sectorial. Ayuda a múltiples entidades a coordinar ante amenazas comunes.	Brinda inteligencia, alertas y soporte al SOC.	El CERT nacional emite alerta sobre vulnerabilidad crítica afectando múltiples organizaciones.



Una estrategia de seguridad corporativa es el conjunto de políticas, procesos, controles y tecnologías que una organización diseña para proteger activos críticos, prevenir ataques, cumplir normativas y garantizar continuidad del negocio. El SOC es el **centro operativo** de esa estrategia.

Visibilidad centralizada	Detección temprana	Respuesta rápida y contenida	Cumplimiento y auditoría	Alineación con objetivos de negocio
Recopila y analiza datos de toda la infraestructura. Permite tomar decisiones basadas en información real (datos, alertas, logs).	Identifica comportamientos anómalos antes de que escalen. Reduce el riesgo y permite respuesta más eficiente.	Ejecuta protocolos para contener, erradicar y recuperar. Minimiza el impacto económico, legal y reputacional.	Documenta incidentes y genera reportes con trazabilidad. Ayuda a cumplir ISO 27001, PCI-DSS, HIPAA o GDPR.	Coordina con IT, legal, RRHH y liderazgo. Protege lo más valioso: operaciones, clientes y reputación.